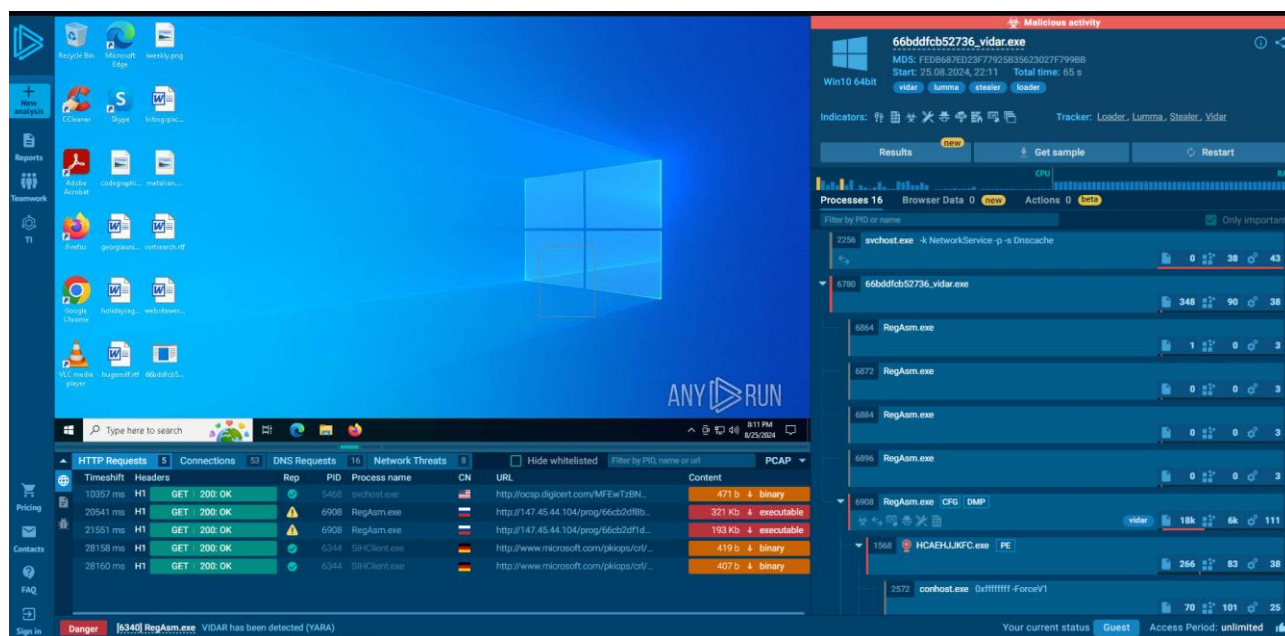


Esercizio 5 — Analisi di due casi ANY.RUN



Destinatari: cliente / management

Obiettivo: valutare le attività osservate e proporre interventi proporzionati al rischio.

L'analisi si basa sulle schermate di due esecuzioni in sandbox ANY.RUN del 25 agosto 2024. La sandbox è un ambiente separato utilizzato per osservare file e collegamenti potenzialmente pericolosi. I risultati descrivono quanto avvenuto durante queste prove; non dimostrano automaticamente una compromissione dei dispositivi aziendali.

Caso 1 — Eseguitabile associato a Vidar e Lumma

Oggetto analizzato: 66bddfcb52736_vidar.exe

Ambiente: Windows 10 a 64 bit

Durata visualizzata: 65 secondi

Verdetto ANY.RUN: "Malicious activity"

Riferimenti: screenshot 1–3.

Evidenze e interpretazione

Le schermate mostrano diversi elementi coerenti con un'attività malevola:

- ANY.RUN associa alla prova le etichette **Vidar**, **Lumma**, **stealer** e **loader**.
- È visibile un rilevamento **Vidar tramite YARA**, cioè una regola che riconosce caratteristiche del malware.
- Il file iniziale avvia più istanze di RegAsm.exe. Una di queste, con PID 6908, effettua due richieste HTTP verso 147.45.44[.]104, ricevendo contenuti classificati come eseguibili, di circa 321 e 193 KB.
- Nell'albero dei processi compare anche un ulteriore eseguibile denominato HCAEHJKFC.exe.

- La piattaforma riporta otto segnalazioni nella sezione “Network Threats”. Non equivalgono necessariamente a otto malware distinti.

RegAsm.exe è un programma legittimo dell’ambiente Microsoft .NET: il suo nome, da solo, non è sospetto. In questo caso, però, la relazione con il campione, i download e il rilevamento Vidar rendono il suo impiego anomalo.

Le richieste verso servizi di Microsoft e DigiCert, anch’esse presenti, non devono essere automaticamente considerate malevole: possono essere attività del sistema relative ai certificati. Analogamente, la posizione geografica di un indirizzo IP non identifica l’autore dell’attacco.

Spiegazione

Il comportamento osservato è compatibile con una minaccia che può **raccogliere informazioni riservate e introdurre ulteriori programmi dannosi**.

Uno *stealer* è un malware progettato per sottrarre informazioni, per esempio credenziali o dati di sessione. Un *loader* serve a introdurre ulteriori componenti nella macchina. Per l’azienda, le conseguenze possibili comprendono accessi abusivi agli account, esposizione di dati e ulteriori infezioni.

La presenza dell’etichetta Lumma va inoltre distinta dal rilevamento Vidar esplicitamente visibile: per approfondire il ruolo dei singoli componenti occorre esaminare i relativi eventi del report completo.

Ulteriori terminologie:

Termine	Spiegazione semplice
PID	Numero che identifica un programma in esecuzione.
HTTP	Protocollo utilizzato per scambiare risorse web.
Hash	Impronta digitale del contenuto di un file, utile per identificarlo.
Vendor	Fornitore del prodotto di sicurezza.
Revoca delle sessioni	Invalidazione degli accessi già attivi agli account.

Classificazione

Valutazione: attività malevola con alta confidenza; rilevamento valutato come vero positivo nel contesto della sandbox.

La decisione si basa sulla convergenza di rilevamento, processi correlati e download di eseguibili, non soltanto sul nome del file. Non emergono elementi sufficienti per considerare il rilevamento un falso positivo.

Remediation proposta

Intervento	Motivazione
Quarantena del file	Impedire nuove esecuzioni, conservando una copia controllata per l'analisi.
Verifica dell'esecuzione sui dispositivi aziendali	La semplice presenza del file non dimostra che sia stato avviato. Cercare riscontri nei log antivirus/EDR, cioè nei sistemi di protezione e monitoraggio delle postazioni.
Isolamento delle postazioni con esecuzione confermata	Limitare ulteriori comunicazioni e attività dannose, mantenendo quando possibile il canale di gestione della sicurezza.
Conservazione delle evidenze	Raccogliere hash, processi, connessioni e log prima della rimozione, per ricostruire l'accaduto.
Blocco mirato degli indicatori confermati	Bloccare il file tramite hash e valutare gli indirizzi/URL coinvolti. Gli indicatori risalgono al 2024: un blocco attuale richiede una verifica, perché gli IP possono cambiare utilizzo.
Protezione degli account potenzialmente esposti	Se l'esecuzione è confermata, valutare revoca delle sessioni, cambio delle credenziali da un dispositivo pulito e controllo degli accessi anomali.
Bonifica o reinstallazione da immagine affidabile	La sola eliminazione del file iniziale potrebbe lasciare altri componenti. Preferire la reinstallazione quando non è possibile garantire una bonifica completa.

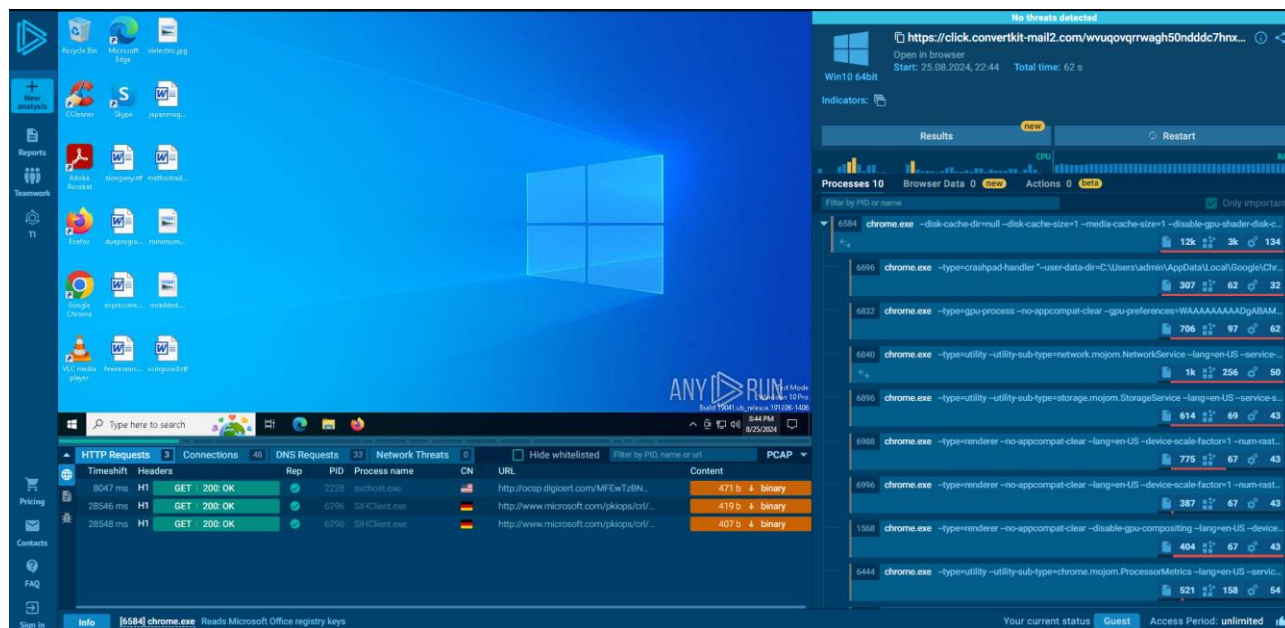
Abbiamo anche:

- **Eliminazione:** rimuovere il campione malevolo e gli eventuali componenti associati dopo aver preservato le evidenze necessarie. La cancellazione del solo file iniziale non garantisce la bonifica della postazione.
- **Blacklist:** bloccare gli hash dei campioni confermati come malevoli tramite gli strumenti di protezione delle postazioni, quando supportato. Applicare eventuali blocchi degli indirizzi IP e degli URL attraverso firewall, proxy o gateway compatibili, dopo aver verificato gli indicatori e valutato il possibile impatto sui servizi legittimi.

Il coinvolgimento del vendor è opportuno se la protezione aziendale non rileva il campione, se i risultati sono discordanti oppure se servono indicazioni specifiche di rimozione. Non deve ritardare il contenimento di una compromissione confermata.

Conclusione: il caso richiede un intervento prioritario se viene riscontrato sui sistemi aziendali. La chiusura richiede verifica della bonifica, controllo degli account eventualmente esposti e assenza di ulteriori indicatori durante il monitoraggio.

Caso 2 — Collegamento con navigazione verso Instagram e Facebook



Oggetto analizzato: URL sul dominio click.convertkit-mail2[.]com

Ambiente: Windows 10 a 64 bit

Durata visualizzata: 62 secondi

Verdetto ANY.RUN: “No threats detected”

Riferimenti: screenshot 4–8.

Evidenze e interpretazione

Il secondo caso riguarda un collegamento web, non un eseguibile.

Le schermate mostrano:

- Una pagina di accesso su instagram.com, con un parametro che rimanda a un profilo Instagram.
- Successivamente, una pagina di accesso su facebook.com.
- Processi chrome.exe con funzioni coerenti con il normale funzionamento del browser, come gestione della rete e visualizzazione delle pagine.
- Zero segnalazioni nella sezione “Network Threats”.
- Tre richieste HTTP visibili verso Microsoft e DigiCert, senza download di eseguibili mostrati in quella tabella.

Le schermate documentano queste destinazioni, ma non l'intera sequenza di navigazione: il passaggio a Facebook potrebbe derivare dall'interazione con "Log in with Facebook", visibile nella pagina Instagram, anziché da un reindirizzamento automatico.

La voce "Reads Microsoft Office registry keys" è classificata come informativa. Una lettura del registro, isolatamente, non prova attività malevola. Inoltre, la dicitura "**binary**" non significa "**malware**": descrive il formato del contenuto.

Spiegazione

Durante la prova **non sono emerse evidenze sufficienti per classificare il collegamento come malware o phishing**. La navigazione visibile è compatibile con un collegamento che conduce a servizi social legittimi.

La presenza di una pagina di login non indica, da sola, un tentativo di furto delle credenziali. In questi screenshot la barra degli indirizzi mostra i domini Instagram e Facebook, elemento favorevole rispetto a una pagina imitativa ospitata su un dominio estraneo.

Tuttavia, ciò non garantisce l'affidabilità del messaggio originale, del profilo social di destinazione o di eventuali interazioni successive. La prova dura circa un minuto e non mostra il completamento dell'autenticazione.

Classificazione

Valutazione: nessuna minaccia rilevata; comportamento osservato presumibilmente benigno, con confidenza moderata.

Il risultato è **compatibile con un vero negativo**, ma per confermarlo occorre verificare il contesto del collegamento e l'intera navigazione.

Non è corretto definirlo automaticamente:

- **Falso positivo:** servirebbe una segnalazione di minaccia poi dimostrata errata.
- **Falso negativo:** servirebbero evidenze di una minaccia reale che il controllo non ha rilevato.

Remediation proposta

Intervento	Motivazione
Nessuna bonifica o isolamento sulla sola base degli screenshot	Non sono mostrate evidenze di compromissione che giustificano queste azioni.
Verifica del messaggio e del mittente	Controllare che il collegamento fosse atteso e coerente con il contenuto ricevuto.
Verifica della catena completa di navigazione	Accertare eventuali passaggi intermedi, download e destinazioni effettive tramite report e log disponibili.

Nessuna blacklist generalizzata	Bloccare interamente Instagram, Facebook o il servizio di collegamenti sarebbe sproporzionato rispetto alle evidenze.
Quarantena temporanea del singolo messaggio, se esistono altri sospetti	Misura reversibile in attesa di chiarimenti su mittente o contenuto, non conseguenza automatica del risultato della sandbox.
Richiesta al vendor solo in caso di incongruenze	Utile se il sistema aziendale segnala phishing o malware mentre questa prova non mostra elementi corrispondenti.

Non è necessario cambiare password soltanto perché è stata visualizzata una pagina di accesso. L'intervento sugli account diventa necessario se emergono prove di credenziali inviate a una destinazione fraudolenta o di accessi non autorizzati.

Conclusione: le evidenze disponibili non giustificano la classificazione del collegamento come minaccia confermata. Si propone una verifica del contesto e, se coerente, la chiusura della segnalazione come attività benigna, documentando i limiti della prova.

Confronto finale

Caso	Valutazione	Decisione principale
1 — Eseguitabile	Attività malevola; vero positivo nella sandbox	Quarantena e verifica dell'esecuzione; isolamento e recupero delle postazioni compromesse.
2 — Collegamento	Nessuna minaccia rilevata; presumibilmente benigno	Verifiche contestuali, senza blocchi generalizzati o bonifiche ingiustificate.

Le classificazioni descrivono l'esito dell'analisi; quarantena, eliminazione e blacklist sono invece azioni operative, da scegliere in base alle evidenze e all'effettiva esposizione aziendale.